Threatscape

Security Concepts

© 2015 Cisco and/or its affiliates. All rights reserved.

Threatscape Overview

- No industry is exempt from attacks.
- Attackers can be:
  - Individuals
  - Small teams of hackers
  - Organized crime
  - National governments
- Attackers are creative thinkers.
- Combining old and new concepts, attacks are always evolving.

© 2015 Cisco and/or its affiliates. All rights reserved.

Threatscape Terminology

Vulnerability: Weakness that compromises either the security or the functionality of a system

Exploit: Mechanism used to leverage a vulnerability to compromise a system

Threat: Circumstance or event with potential to cause harm to an asset

Risk: Likelihood that a particular threat using a specific attack will exploit a particular vulnerability of an asset

© 2015 Cisco and/or its affiliates. All rights reserved.

DoS Attacks

- Attempt to make a computer or network resource unavailable for intended use
  - Consume all of a critical resource
  - Cause a system to crash
- Considered a major risk
- Can easily disrupt the operations of a business
- Relatively simple to conduct
- Examples:
  - TCP SYN Flood
  - Ping of Death
- Generally sourced from a single system

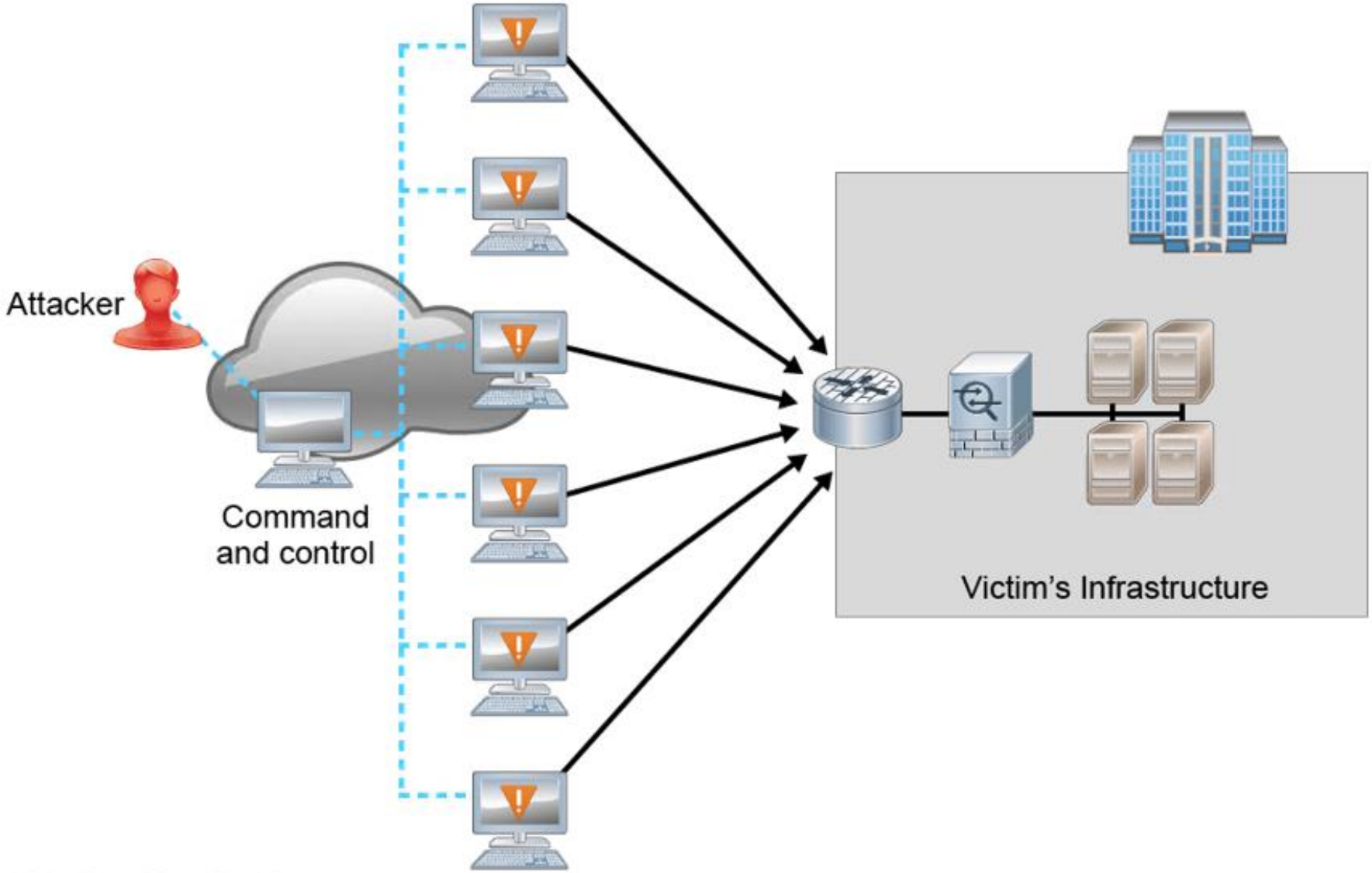
© 2015 Cisco and/or its affiliates. All rights reserved.

DDoS Attacks

- DoS attacks that simultaneously leverage a large number of attacking systems
- Typically utilize botnets
  - Group of "zombie" computers that run bots
  - Master control mechanism that controls the zombies

© 2015 Cisco and/or its affiliates. All rights reserved.

Botnet DDoS Attacks



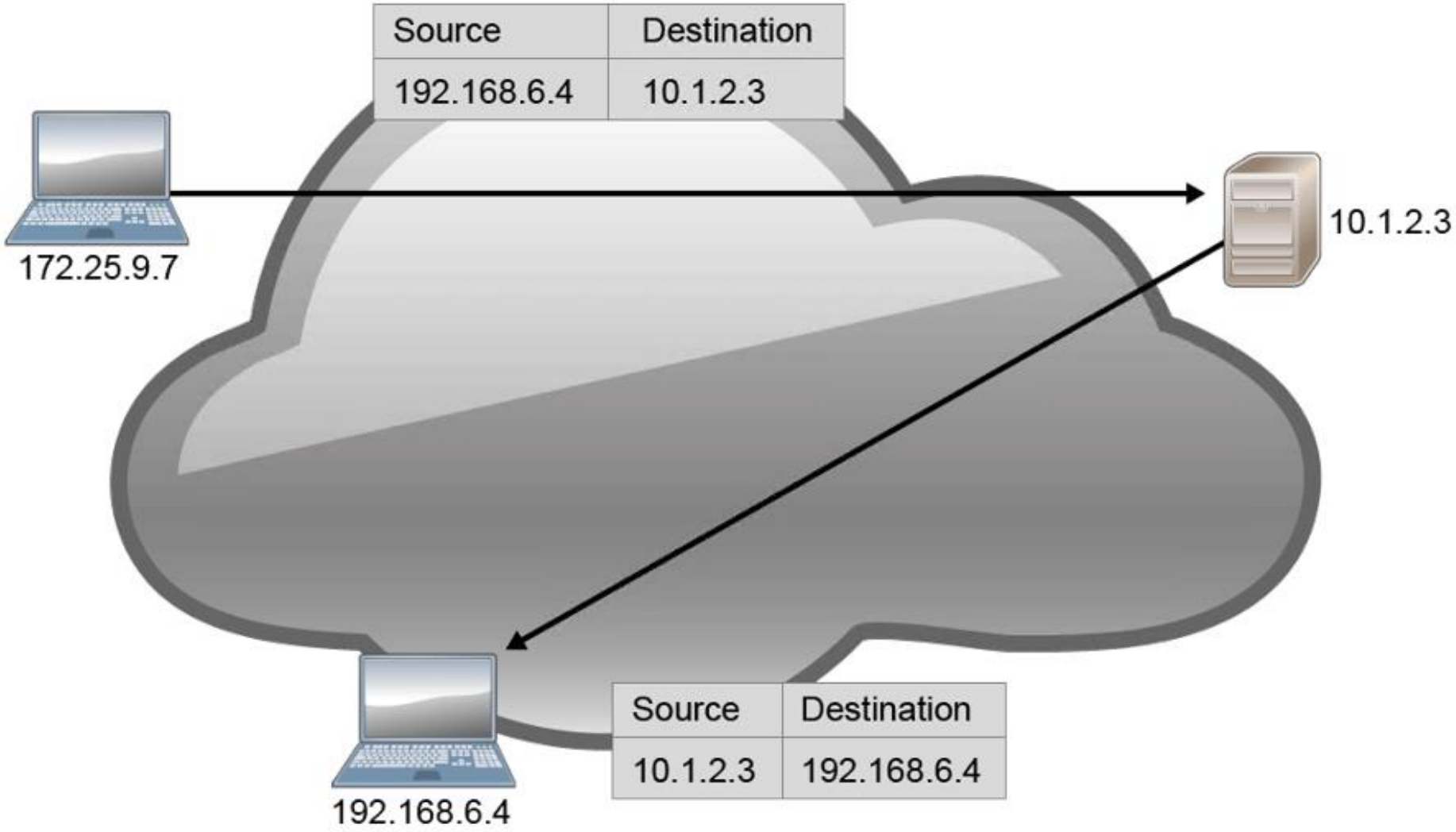
© 2015 Cisco and/or its affiliates. All rights reserved.

Spoofing

- Injecting traffic that appears to be sourced from a system other than the attackering system itself
- Not an attack in itself; it is a technique that can be leveraged in various types of attacks
- Types of spoofing:
  - IP address spoofing
  - MAC address spoofing
  - Application or service spoofing: DHCP, DNS, routing protocols, Email, etc.

© 2015 Cisco and/or its affiliates. All rights reserved.

IP Address Spoofing



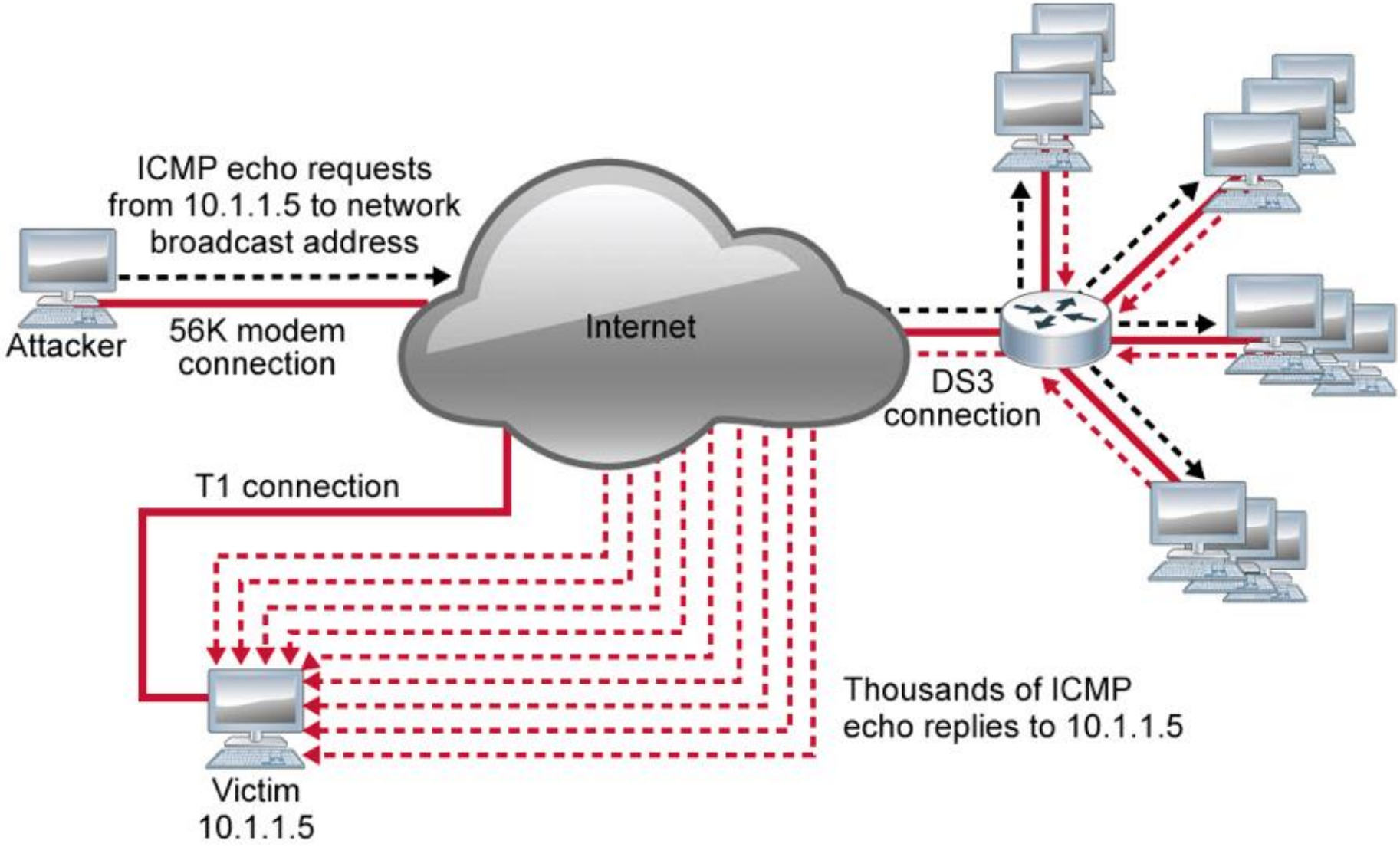
© 2015 Cisco and/or its affiliates. All rights reserved.

Reflection and Amplification Attacks

- In a reflection attack, the attacker sends request packets with spoofed IP addresses to get other hosts to flood a victim.
- A reflection attack can also be an amplification attack if the request packets solicit a larger response.
- In an amplification attack, the attacker sends small forged request packets to elicit a large reply.
- Reflection and amplification attacks are hard to trace because the actual source of the attack is hidden.

© 2015 Cisco and/or its affiliates. All rights reserved.

Smurf Attack



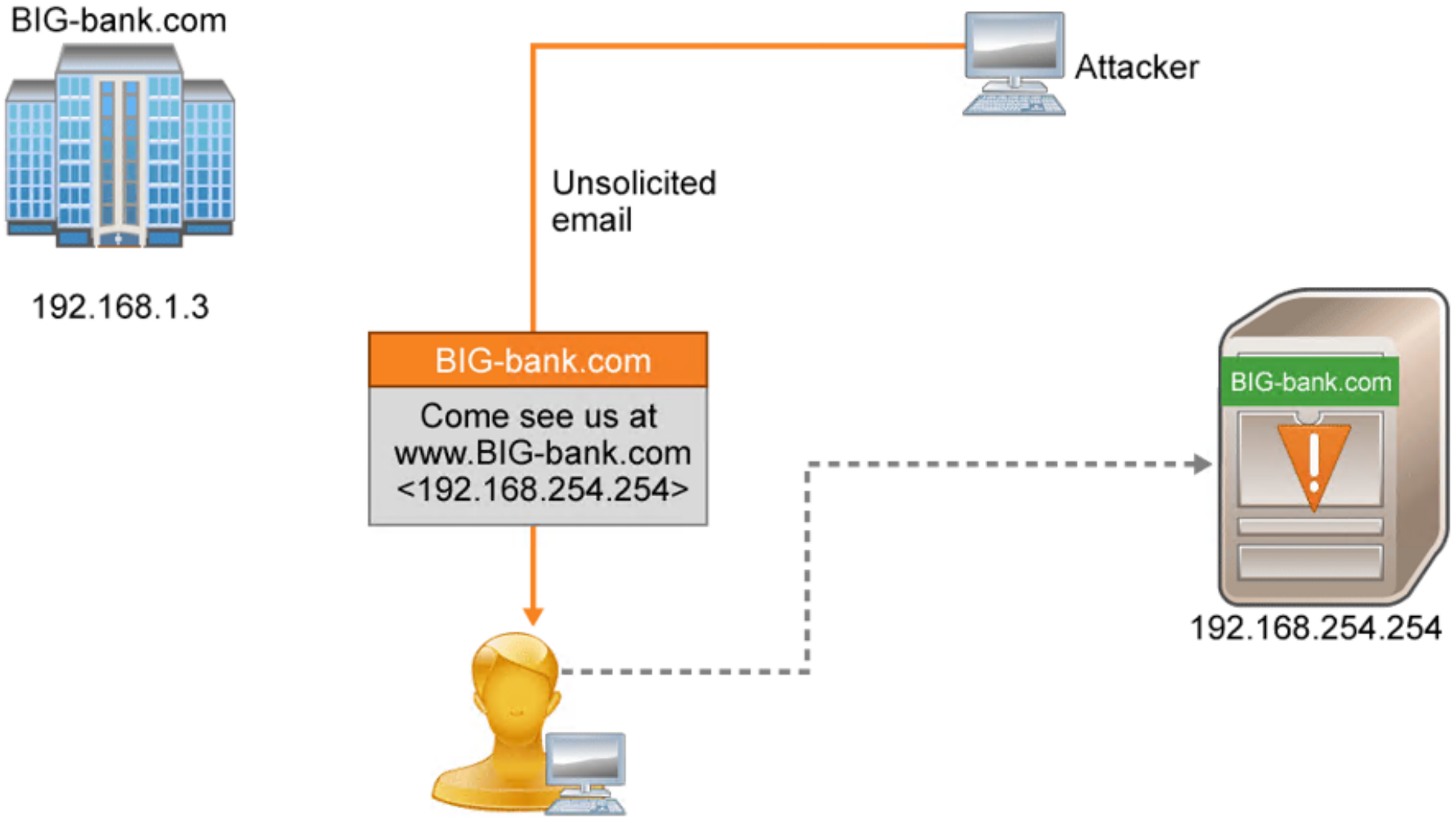
© 2015 Cisco and/or its affiliates. All rights reserved.

Social Engineering

- Manipulating people and capitalizing on expected behaviors
- Examples of social engineering:
  - Phone scams
  - Phishing
  - Tailgating
  - "Lost" USB memory key
  - Visual hacking (shoulder surfing)

© 2015 Cisco and/or its affiliates. All rights reserved.

Phishing



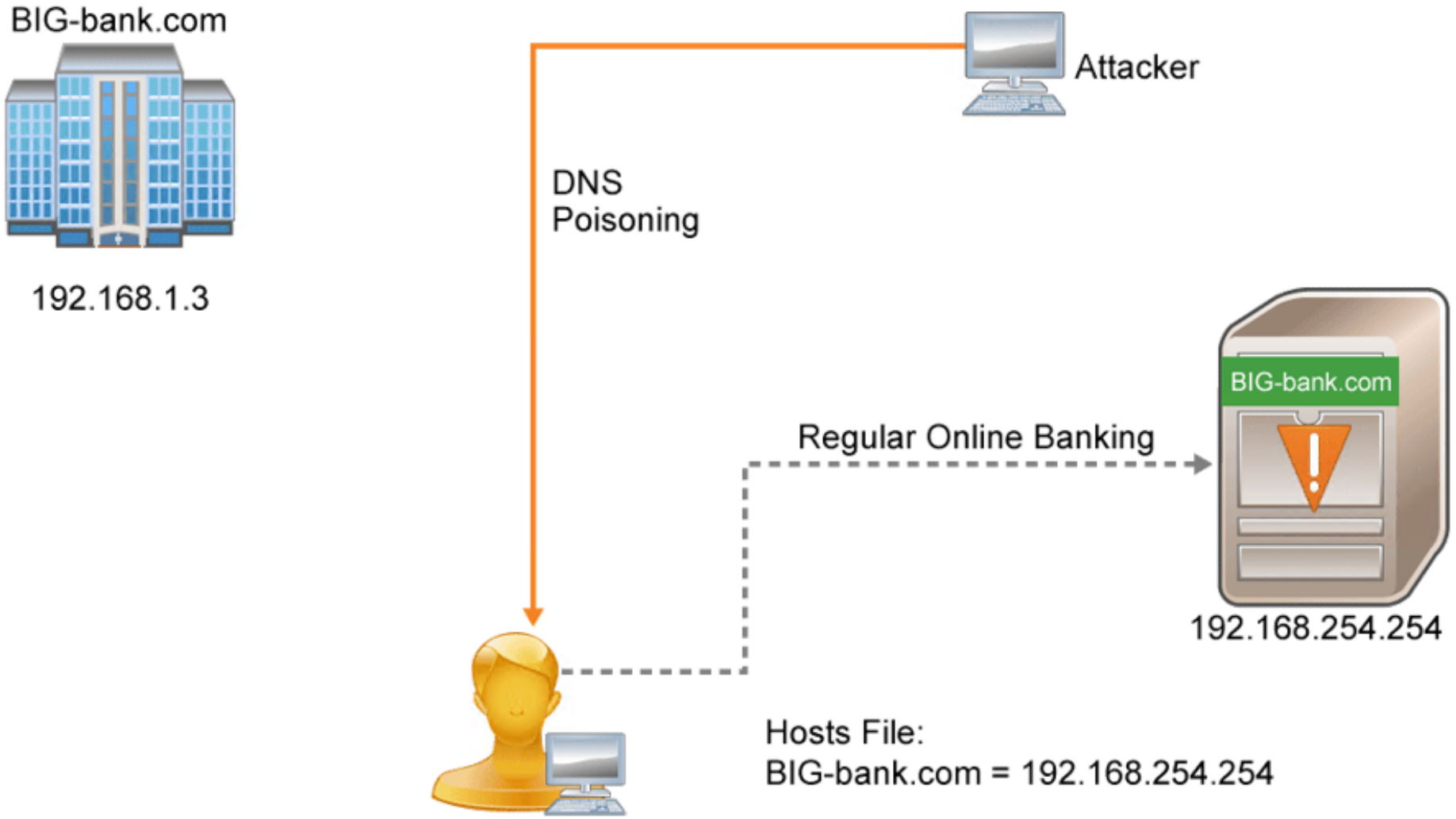
© 2015 Cisco and/or its affiliates. All rights reserved.

Evolution of Phishing

- **Spear phishing:** Phishing that targets individuals or groups
- **Whaling:** Phishing that targets high profile individuals or groups
- **Pharming:** Lures victims by compromising DNS
- **Watering hole:** Attack that leverages a compromised web server to target a select group
- **Vishing:** Phishing that uses voice and the phone system as its medium instead of email
- **Smishing:** Phishing that uses SMS texting as its medium instead of email

© 2015 Cisco and/or its affiliates. All rights reserved.

Pharming



© 2015 Cisco and/or its affiliates. All rights reserved.

Password Attacks

- Methods of obtaining passwords include:
  - Guessing
  - Brute force
  - Dictionary attacks
- Access options:
  - Online
  - Offline
- To prevent password attacks, many authentication systems require a degree of password complexity.
  - Minimum length
  - Enforcement of enlarged character set
  - Human factors, such as use of simple transforms, can diminish effectiveness

© 2015 Cisco and/or its affiliates. All rights reserved.

Reconnaissance Attacks

- A reconnaissance attack is an attempt to learn more about the intended victim before attempting a more intrusive attack.
- Options include:
  - Use standard networking tools such as dig, nslookup, and whois to obtain information such who owns a particular domain and what addresses have been assigned to that domain
  - Perform ping sweeps of the addresses obtained to determine which ones are live hosts.
  - Run port scans on the live hosts to determine what services are running on the hosts.
  - Use the information obtained to determine the easiest way to exploit a vulnerability.
- Vulnerability scanners can be used to locate vulnerabilities in your own network and patch them before they can be exploited.

© 2015 Cisco and/or its affiliates. All rights reserved.

Buffer Overflow Attacks

- Vulnerable service accepts too much input and writes it to memory:
  - Fills up the associated buffer
  - Overwrites adjacent memory
  - May corrupt the system and cause it to crash, resulting in a DoS
  - Potential to inject malicious code, leading to system compromise
- Common vector for client side attacks

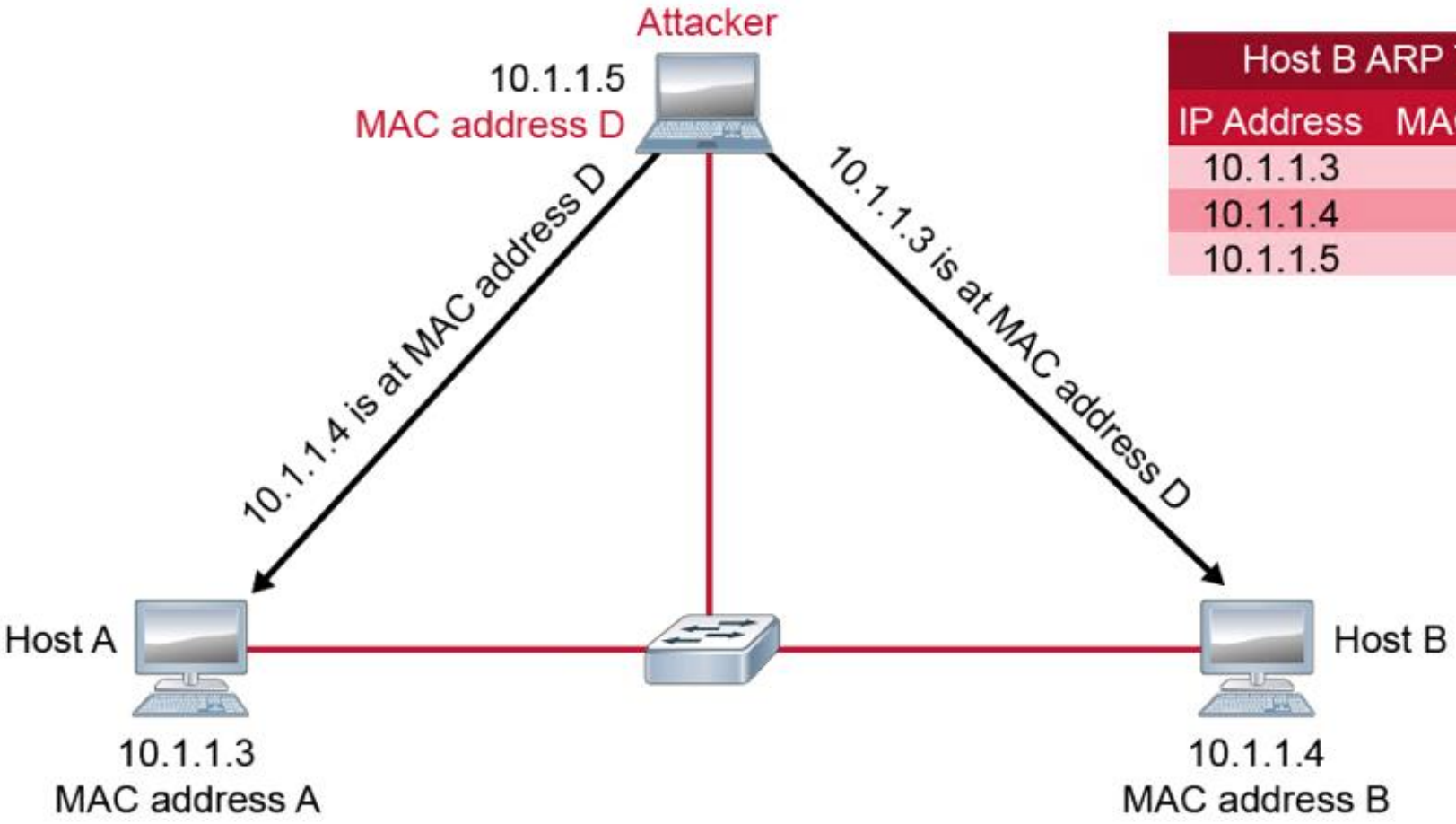
© 2015 Cisco and/or its affiliates. All rights reserved.

Man-in-the-Middle Attack Overview

- Generalized concept that can be implemented in many different scenarios
- Attacking system imposes itself in the communication path between two other systems
- Normally involves attack against networking protocols (such as ARP, DNS, DHCP, or IP routing protocols), resulting in the misdirection of traffic
- Can be passive or active
  - **Passive**: Attacker steals confidential information
  - **Active**: Attacker modifies data in transit or injects data of his own

© 2015 Cisco and/or its affiliates. All rights reserved.

Man-in-the-Middle Attack Example



Host B ARP Table	
IP Address	MAC Address
10.1.1.3	D
10.1.1.4	B
10.1.1.5	D

© 2015 Cisco and/or its affiliates. All rights reserved.

Types of Malicious Software

- Worms
- Viruses
- Trojan horses

© 2015 Cisco and/or its affiliates. All rights reserved.

Internet Worm Survey

- 1988: Morris Worm
  - Multiple vectors: sendmail, finger, rsh/rexec
  - Used local resources: C compiler, words file
- 1999-2004: Melissa, ILOVEYOU, Anna Kournikova, Code Red, Nimda, SQL Slammer, MyDoom, Sasser, ...
  - Wreaked havoc, consuming network, system and human resources
  - Non-targeted
- 2008: Conficker
  - Resulted in a botnet with millions of infected machines
- 2010: Stuxnet
  - Designed to attack industrial programmable logic controllers
  - Targeted Iran's nuclear program
  - Destroyed approximately one fifth of Iran's nuclear centrifuges

© 2015 Cisco and/or its affiliates. All rights reserved.

Advanced Persistent Threats

- A set of continuous hacking processes targeting a specific entity
- Use advanced intelligence gathering techniques
- Can discover and exploit zero-day vulnerabilities
- Stealthy
- Goal is evading detection and maintaining presence
- Typical methodology:
  1. Initial compromise
  2. Escalation of privileges
  3. Internal reconnaissance
  4. Lateral propagation, compromising other systems on track towards goal
  5. Mission completion

© 2015 Cisco and/or its affiliates. All rights reserved.

Vectors of Data Loss and Exfiltration

- Email attachments
- Unencrypted devices
- Cloud storage services
- Removable storage devices
- Improper access controls

© 2015 Cisco and/or its affiliates. All rights reserved.

Hacking Tools

- The difference between a security tool and an attack tool is in the intent of the user.
- The use of network security tools on a network is usually a violation of the security policy governing the network. Never experiment with network security tools on a network unless you have explicit authorization to do so.

© 2015 Cisco and/or its affiliates. All rights reserved.

Hacking Tools (Cont.)

- sectools.org
  - Surveys the network security community and catalogs most popular security tools
  - Descriptions, reviews, links to publisher web sites
  - Password auditors, sniffers, vulnerability scanners, packet crafters, penetration test tools
- Kali Linux
  - Packages over 300 tools in a live Linux distribution
  - Well supported through more than a decade of evolution
  - Continues to be updated to remain current and relevant
- Metasploit
  - Offers hundreds of exploit modules to pair with dozens of payloads
  - Lowers the threshold of experience required to perform sophisticated attacks

© 2015 Cisco and/or its affiliates. All rights reserved.

Network Security Myths

- No one would be interested in my network.
- We have never been hacked.
- IT staff is responsible for implementing security
- We have a firewall in place, we are secure

© 2015 Cisco and/or its affiliates. All rights reserved.